

Lab activity: Detecting access control violations with OWASP ZAP

Learning objectives

By the end of this lab, you will be able to:

- use basic Linux commands to navigate and manage files
- use OWASP ZAP to simulate access control attacks
- analyse logs to detect unauthorised access attempts.

What you will do and why

- Node-based DVWA = vulnerable web app to scan
- Launch OWASP ZAP and scan the application
- ZAP = attacker/emulator
- Analyse ZAP outputs

Step 1: Getting started with Linux

Open the terminal in the Coursera Linux VM and try these commands:

- `pwd` # Shows your current directory
- `ls` # Lists files in the current directory
- `cd /home/coder/Desktop` # Changes to the /opt directory
- `mkdir testlab` # Creates a folder named testlab
- `cd testlab` # Moves into the testlab folder
- `touch notes.txt` # Creates an empty file called notes.txt
- `open notes.txt` # Opens the file

Step 2: Simulate access control attacks with OWASP ZAP

1. Open the Terminal and run this command: **node /home/coder/Desktop/exercise/dvwa_node_app/server.js**
2. This will run the vulnerable app on port 3000
3. Visit the URL using Chrome and make sure the app is running: **localhost:3000**
4. Open OWASP ZAP GUI (on desktop).
5. Use it to scan the provided vulnerable node application.
6. Target URL: **localhost:3000**
7. Use the Spider and Active Scan tools.
8. Quick Start → Automated Scan.

Step 3: Analyse ZAP logs

After the scan, check ZAP logs.

Look for:

- unauthorised access attempts
- suspicious HTTP requests
- any alerts or notices.

Step 4: Reflect

Try and answer the following questions.

- Check the vulnerable application code inside:
/home/code/Desktop/exercise/dvwa_node_app/server.js
- What suspicious activity did you find in the ZAP file?
- What could be improved?